

竞态条件漏洞实验补充说明

1 概述

你需要按照 SEED Labs 实验手册 (Homework_7_Manual_Race_Condition.pdf, 有中英文版) 填写作业模板 (Homework_7_template.docx) 完成作业 7。本文档将某些操作进行说明, 方便你顺利完成作业。

2 环境配置

本实验无需建立容器镜像。

2.1 关闭防护机制

实验手册中提到, 在 Ubuntu 20.04 上, 你需要关闭两种防护措施。在执行指令关闭之前, 你可以运行下两条指令查看目前这两条防护措施的对值 (应该依次为 1 和 2), 方便你之后还原防护措施。

```
sudo sysctl fs.protected_symlinks
```

```
sudo sysctl fs.protected_regular
```

3 任务 1: 选择目标

警告: 本任务中要修改的 `/etc/passwd` 文件是用户管理的核心文件, 误修改或删除可能导致你无法再登录虚拟机账户。强烈建议你在完成此任务前使用 VirtualBox 的快照功能对虚拟机进行存档。

你可以执行 `sudo gedit /etc/passwd` 指令打开文件进行编辑, 如果出现页面滚动问题, 还原记事本窗口的大小再最大化可以解决。在添加条目后, 执行 `su test` 指令即可登录 `test` 账户, 要求输入密码时直接留空 (按回车) 即可。登录 `test` 账户后会看到命令提示符变化。执行 `exit` 指令即可退出。

4 任务 2: 启动竞态条件攻击

4.1 任务 2.A: 模拟一个慢速机器

在本任务中, 我们将通过人为延迟来观察并实现竞态条件攻击。具体步骤与原理如下:

1. 准备初始环境 (绕过检查阶段)

首先, 创建一个你拥有读写权限的普通文件 (例如在 `LabsetupRace` 文件夹中创建一个 `test` 文件, 该文件的绝对路径为 `/home/seed/LabsetupRace/test`)。使用 `ln -sf` 指令将 `/tmp/XYZ` 指向该文件。

2. 运行 vulp 程序并输入任务 1 中的“魔法口令”

运行重新编译后的 `vulp` 程序, 输入“魔法口令”并按回车。此时 `vulp` 程序会先调用 `access()` 检查调用者是否有权写入 `/tmp/XYZ`。由于此时它指向你在第一步中创建的文件, 检查会正常通过。

3. 利用竞态条件执行攻击

程序在通过 `access()` 检查后会执行 `sleep(10)`, 进入 10 秒的暂停状态。此时, 你可以在 10 秒内在另一个终端窗口中再次执行 `ln -sf` 指令, 将 `/tmp/XYZ` 的指向改为 `/etc/passwd`。

4. 结果验证 (利用写入阶段)

当 10 秒倒计时结束, 程序会唤醒并执行 `fopen()`。由于此时 `/tmp/XYZ` 已指向 `/etc/passwd`, 且程序的 `access()` 检测已通过, 它会将“魔法口令”写入系统密码文件, 完成攻击。

4.2 任务 2.B: 真正的攻击

请直接读完本节，并使用 **防护措施** 一节开始前给出的新策略进行攻击。这种新攻击方式对应英文手册中的任务 2.c，但中文手册直接把 2.b 和 2.c 合并了，相当于你无需完成英文实验手册中 2.b 的内容，而是直接从 2.c 开始。

简单来说，在本任务中你需要先修改并执行 LabsetupRace 文件夹中的 target_process.sh 脚本，高频运行 vulp 程序（删除 sleep(10); 语句）。接下来，在另一个终端窗口中运行实验手册中本任务最后的示例程序，调换指向对象。理论上，运行示例程序后你的脚本会几乎立即显示攻击完成。

5 防护措施

5.1 应用最小权限原则

在此任务中，你可以在源代码开头部分声明以下两个变量并分别赋 uid 和 euid 的值：

```
uid_t real_uid = getuid();  
  
uid_t eff_uid = geteuid();
```

接下来，在源代码中合适的位置插入 seteuid(real_uid); 和 seteuid(eff_uid); 即可。应当在 fopen() 之前插入 seteuid(real_uid); 以降低权限，在 fclose() 之后（如果后续还有 root 任务）或程序结束前插入 seteuid(eff_uid); 以恢复权限。

5.2 使用 Ubuntu 内置方案

本任务没有需要说明的部分。

6 提交

请在作业 7 模板（Homework_7_Template.docx）上完成，**生成 pdf 文件并提交**。不要提交 .docx 文件。